

Auth Service

Định danh và xác thực người dùng

Nhóm bài tập lớn Công nghệ Web

Cập nhật: 26/05/2026

1. Trách nhiệm

Auth Service chạy tại cổng 3000, quản lý đăng ký, đăng nhập, gửi email khôi phục mật khẩu, cập nhật mật khẩu và xác minh liên kết/OTP email. Dịch vụ sử dụng Supabase Auth cho tài khoản và bảng profile cho thông tin ứng dụng.

2. Các endpoint chính

HTTP	Endpoint	Mục đích
POST	/sign-up	Tạo tài khoản người dùng
POST	/sign-in	Trả session token và thông tin vai trò
POST	/forgot-password	Gửi email khôi phục mật khẩu
POST	/refresh-password	Đặt mật khẩu mới từ access token
POST	/send-email-otp	Gửi mã OTP email
POST	/verify-email-otp	Kiểm tra OTP
POST	/verify-email-link	Xác nhận token từ liên kết email

3. Luồng đăng ký

1. Controller nhận email, password và redirect URL tùy chọn.
2. Repository chuẩn hóa email: loại khoảng trắng và đổi sang chữ thường.
3. Repository kiểm tra tài khoản trùng trong danh sách user của Supabase.
4. Supabase Auth tạo user mới kèm metadata role = user.
5. Sau khi tạo auth user thành công, service upsert bản ghi profile với email và tên mặc định.
6. Frontend yêu cầu người dùng kiểm tra email để xác minh tài khoản.

4. Luồng đăng nhập

Email được chuẩn hóa rồi gửi tới Supabase Auth cùng mật khẩu. Nếu có session hợp lệ, controller trả về access_token và payload gồm userId, email, role. Gateway chuyển payload này về frontend để quản lý trạng thái đăng nhập.

5. Vì sao thiết kế như vậy

- Supabase giảm khối lượng phải tự xây dựng về lưu mật khẩu, email verification và recovery.

- Chuẩn hóa email tránh một người tạo nhiều tài khoản chỉ vì khác chữ hoa/thường.
- Tách repository khỏi controller giúp test response của controller mà không cần gọi dịch vụ thật.

6. Dữ liệu và cấu hình

Cần cấu hình SUPABASE_URL, SUPABASE_ANON_KEY, SUPABASE_SERVICE_ROLE_KEY và URL redirect email. Service role key là thông tin nhạy cảm, chỉ lưu phía backend.